

De-risking 3rd-Party & Supply Chain Access

Contractors, suppliers and partners need access to a handful of internal applications — legacy VPN gives them the whole network. This use case replaces implicit-trust remote access with identity-driven, posture-aware ZTNA: least-privileged access, enforced in the cloud, with no appliances to deploy.

ZTNA

Device Posture

FWaaS

CASB

DLP

Client Connectivity Policy

BUSINESS OBJECTIVE

Why this matters

Third-party and supply-chain access is one of the most exploited paths into the enterprise. The people who need access — IT providers, debt-collection agencies, logistics partners, offshore developers — are exactly the users the business controls least: unmanaged devices, unknown security posture, credentials that outlive the contract.

The objective is simple to state and hard to do with legacy tooling: **give every third party access to exactly what they need, nothing more, and prove it.**

Impact of 3rd-party supply-chain breaches

High-profile organisations have been breached through supplier and third-party access — recent examples worth naming in the room:

£2_B

Estimated cost to the UK economy
— Jaguar Land Rover (2025)

4.2_M

Customers' PII leaked — Truist
Bank via 3rd-party agency (2024)

£300_M

Losses from ~2 months of e-commerce downtime — M&S
(2025)

Jaguar Land Rover 2025

Compromised credentials allowed access to an internal Jira server, which was exploited and PII leaked. Huge reputational damage and an estimated £2B cost to the UK economy.

Truist Bank 2024

A third-party debt-collection agency was breached — and that agency had access to sensitive Truist data. PII of nearly 4.2 million people leaked; lawsuits, reputational damage, and an estimated \$400–600M in damages.

Marks & Spencer 2025

Compromised credentials from a contractor IT provider. The online store was down for nearly two months — losses up to £300M and a £1B drop in market valuation.

Why legacy 3rd-party access fails

Legacy VPN

- Designed for connectivity, not security
- Overly permissive — built on implicit trust
- No segmentation → free lateral movement once inside
- No visibility of what third parties actually do
- Compromised credentials unlock the whole network

On-premise appliances

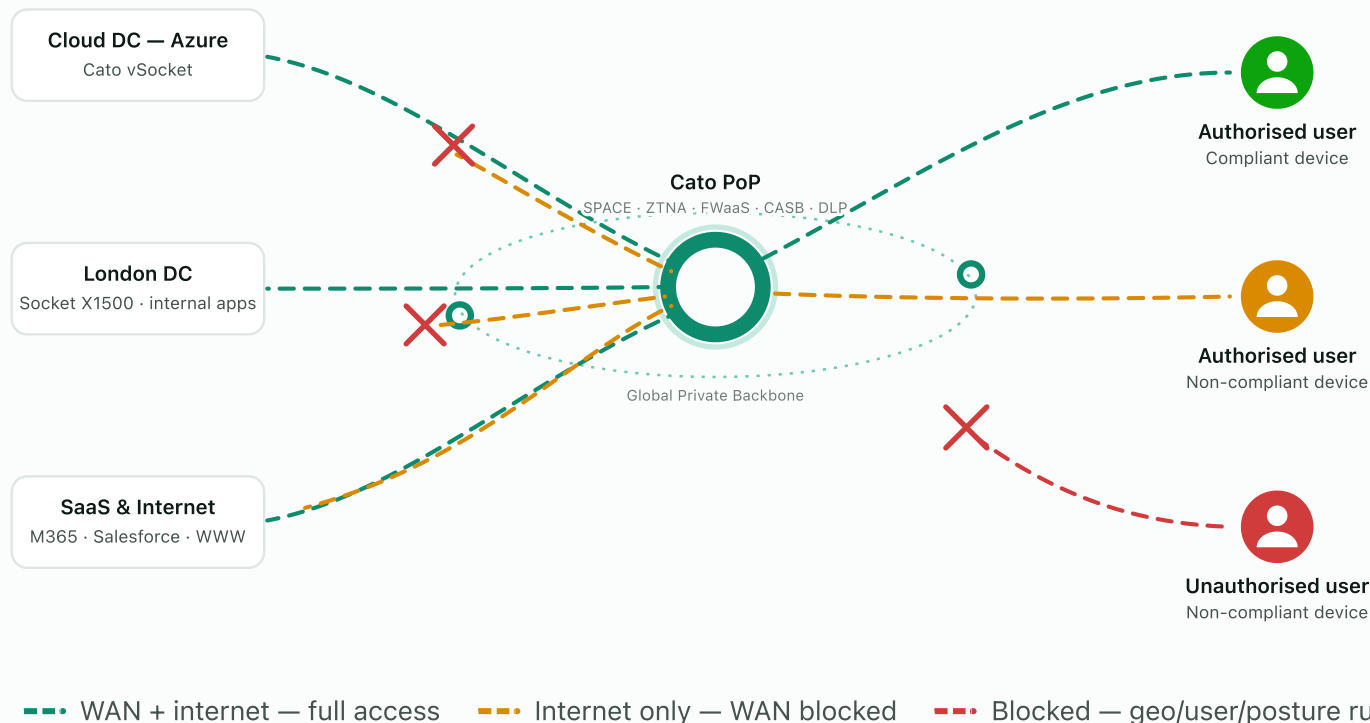
- Constant maintenance, patching and management
- Extra appliances needed to bolt on security
- Scalability challenges as third-party count grows
- No consistent security across regions and entities
- Increases both time and cost per onboarded supplier

Discovery question

"How many third parties can reach more than the one application they were onboarded for — and how would you know if one of their accounts was compromised today?"

Removing risk through least-privileged access

Cato enforces a consistent, identity-driven policy on every user, everywhere. Access decisions combine **who the user is** (IdP identity and group) with **the state of their device** (posture profile: EPP/EDR running, disk encryption, OS version, client version...), continuously verified throughout the session — not just at login.



Access decisions combine user authorisation with live device posture. The same user gets different access as their device state changes.

Zero trust: trust but verify — continuously

Consistent policy for users everywhere

Identity-driven and globally enforced from every PoP — no backhauling to a single VPN appliance, no regional policy drift.

Access control with device posture

Posture profiles (EPP/EDR present, encryption, OS patch level) gate access before and during every session.

Threat prevention on every flow

FWaaS, SWG, IPS and anti-malware inspect third-party traffic the same as employee traffic — nothing rides in unexamined.

Sensitive data protection

DLP and risk-based application controls (CASB) stop contractors exfiltrating data to personal cloud apps.

How to run the demo

Before you demo — dig into the “why”

Open with discovery: why are they looking at third-party access security now? Which suppliers, which applications, what triggered it (audit, incident, renewal)? Anchor the demo to their answer.

1 Set the scene with the business impact

Walk the breach examples above — pick the one closest to the prospect's industry. Then contrast with how their third parties connect today (usually VPN + jump hosts).

2 Show initial connectivity control

[Access → Client Connectivity Policy](#)

Show geo-blocking rules, rules scoped to user groups, and internet-only rules — the first gate that decides who can even establish a tunnel, from where, on what device.

3 Show least-privileged WAN access

[Security → WAN Firewall](#)

Walk the rule set: contractor user groups allowed to reach only their named resources; corporate users required to match a compliant device-posture profile for wider access.

4 Show device posture profiles

[Access → Device Posture](#)

Open a posture profile and show the criteria available — running EPP/EDR, disk encryption, OS version, domain membership, client version. Explain continuous (not login-only) evaluation.

5 Live proof: the contractor experience

Log in as a contractor user. Show them **blocked** from an internal resource but able to reach their permitted portal. The two demo prop pages ship with this use case:

- [Contractor portal](#) — the resource the contractor *can* reach
- [Internal portal](#) — the resource that stays blocked

6 Close on visibility

[Monitor → Events](#)

Filter events to the contractor's identity: every allow and block, fully attributed. “This is the audit trail you don't have today.”

Narrative for the solution slide

Hybrid workforce reality. Enterprises need to connect users securely wherever they are — office, customer sites, travel, home. Third parties are part of that same workforce now.

Consistent policy, delivered from the cloud. Cato enforces policy based on identity, distributed globally and enforced consistently — no backhauling across the world to a single VPN appliance, no global instance sprawl to achieve the same goal.

True zero trust with continuous verification. Access control, threat prevention and data protection are enforced on all traffic throughout the session — proven at scale when customers moved their entire workforce remote during COVID without giving up security.

GO DEEPER

Resources

Documentation

- [Client Access & Device Posture \(KB\)](#)
- [Universal ZTNA — platform page](#)
- [CASB — platform page](#)

In this library

- [Securing the Hybrid Workforce](#)
- [BYOD & Unmanaged Device Access](#)
- [Consistent Security Everywhere](#)